STARWEAVER®

Hands-On-Learning: The NIST Resilience Gap Analysis

Learning Objectives

By the end of this activity, learners will be able to:

- Evaluate an organization's security posture using the NIST Cybersecurity Framework (CSF).
- Identify critical gaps in business continuity and resilience planning.
- Recommend appropriate ISO standards to fortify recovery processes.



Description

In this hands-on activity, learners will explore how global frameworks are used to build organizational resilience. Using a provided case study of a mid-sized retail company that recently suffered an outage, learners will map the company's current capabilities against the NIST CSF core functions and propose actionable improvements.

Structure of the Activity: Title: The NIST Resilience Gap Analysis

Tools used: NIST CSF documentation, Company X Case Study document, NIST–ISO Simplified Resilience Checklist (provided)

Scenario

You have been hired as a Resilience Consultant for "Company X," a mid-sized retail chain. Last month, a server failure caused a 48-hour outage. Reviewing their internal documents, you see they have strong firewalls but no off-site backups and outdated incident logs. Your task is to use the NIST CSF to identify where they are failing and propose a framework for improvement.

Objective

Your goal is to conduct a structured resilience gap analysis for Company X and produce a prioritized set of improvement recommendations grounded in global frameworks. This exercise will help you apply the NIST CSF functions to a real-world scenario, evaluate gaps using a checklist methodology, and connect ISO standards to specific recovery capability shortfalls.



Instructions for learners

1. **Exploration:**

- Review the Company X Case Study.
- Using the NIST–ISO Simplified Resilience Checklist provided, map their current tools and missing processes to the five NIST CSF functions:
- Identify, Protect, Detect, Respond, Recover.
  Mark each checklist item as Present, Partial, or Missing for Company X.

2 Gap Identification:

- From your completed checklist, identify the three most critical resilience gaps in Company X's current posture.
- For each gap, note which NIST function it falls under and the likely business impact if left unaddressed.
- Rank the three gaps in order of urgency.

3 Reflection:

- Select one ISO standard — ISO 22301 for business continuity or ISO 27001 for information security management.
- Write a brief justification (3–4 sentences) explaining how implementing this standard would specifically address the Recover function gap identified for Company X.
- Reference at least one specific requirement or control area from the standard in your justification.

Organize Information Following This Structure for Peer Review:

- **Title Page:** Activity title, your name, date.
- **NIST Framework Mapping:** A brief list mapping Company X's current state to the five NIST functions.
- **Critical Resilience Gaps:** The top three vulnerabilities you identified in their continuity planning.
- **Reflections and Framework Recommendations:** Explain how implementing an ISO standard will improve their specific recovery capabilities.

Instructions for Documenting and Sharing the Project for Peer Review

Document the Project

- Use word processing software to create your project summary and reflections.
- Ensure all sections of the project document structure are completed.
- Proofread and edit your report for clarity and accuracy.

Share the Project

- Save your report in PDF format.
- Upload your documents to the “Peer Review” area in the course shell.
- Provide a brief description of your project in the submission post.

Peer Review

- Review the projects submitted by your peers.
- Provide constructive feedback and comments on the accuracy of their NIST mapping, the quality of the gap prioritization, and the strength of their ISO standard justification.

This activity gives learners a chance to apply the lesson by conducting a real-world style gap analysis that translates global resilience frameworks into actionable improvement recommendations for an organization.